

TECHNIQUES

- Access Token Manipulation
- Token Impersonation/Theft
- Create Process with Token
- Make and Impersonate Token
- Parent PID Spoofing
- SID-History Injection
- Account Manipulation
- Boot or Logon Autostart Execution
- Boot or Logon Initialization Scripts
- Create or Modify System Process
- Domain or Tenant Policy Modification
- Escape to Host
- Event Triggered Execution
- Exploitation for Privilege Escalation
- Process Injection
- Scheduled Task/Job
- Valid Accounts
- Stealth
- Defense Impairment

Home > Techniques > Enterprise > Access Token Manipulation > Token Impersonation/Theft

Access Token Manipulation: Token Impersonation/Theft

Other sub-techniques of Access Token Manipulation (5)

Adversaries may duplicate then impersonate another user's existing token to escalate privileges and bypass access controls. For example, an adversary can duplicate an existing token using `DuplicateToken` or `DuplicateTokenEx`.^[1] The token can then be used with `ImpersonateLoggedOnUser` to allow the calling thread to impersonate a logged on user's security context, or with `SetThreadToken` to assign the impersonated token to a thread.

An adversary may perform Token Impersonation/Theft when they have a specific, existing process they want to assign the duplicated token to. For example, this may be useful for when the target user has a non-network logon session on the system.

When an adversary would instead use a duplicated token to create a new process rather than attaching to an existing process, they can additionally Create Process with Token using `CreateProcessWithTokenW` or `CreateProcessAsUserW`. Token Impersonation/Theft is also distinct from Make and Impersonate Token in that it refers to duplicating an existing token, rather than creating a new one.

ID: T1134.001

Sub-technique of: T1134

Tactics: Stealth, Privilege Escalation

Platforms: Windows

Contributors: Jonny Johnson

Version: 2.0

Created: 18 February 2020

Last Modified: 12 May 2026

Version Permalink

Procedure Examples

ID	Name	Description
G0007	APT28	APT28 has used CVE-2015-1701 to access the SYSTEM token and copy it into the current process as part of privilege escalation. ^[2]
S0456	Aria-body	Aria-body has the ability to duplicate a token from ntprint.exe. ^[3]
S1081	BADHATCH	BADHATCH can impersonate a lsass.exe or vmtoolsd.exe token. ^[4]
S0570	BitPaymer	BitPaymer can use the tokens of users to create processes on infected systems. ^[5]
S0154	Cobalt Strike	Cobalt Strike can steal access tokens from exiting processes. ^{[6][7]}
S0367	Emotet	Emotet has the ability to duplicate the user's token. ^[8] For example, Emotet may use a variant of Google's ProtoBuf to send messages that specify how code will be executed. ^[9]
G0061	FIN8	FIN8 has used a malicious framework designed to impersonate the lsass.exe/vmtoolsd.exe token. ^{[10][11]}
S0182	FinFisher	FinFisher uses token manipulation with NtFilterToken as part of UAC bypass. ^{[12][13]}
S9033	Fooder	Fooderhas used the DuplicateTokenEx API to duplicate the token of a specified process, and CreateProcessAsUserA to execute its payload. ^[14]
S1229	Havoc	Havoc has a module capable of token impersonation. ^[15]
C0038	HomeLand Justice	During HomeLand Justice, threat actors used custom tooling to acquire tokens using ImpersonateLoggedOnUser/SetThreadToken. ^[16]
S9036	LP-Notes	LP-Notes has impersonated the security context of the taskhostw.exe process via the ImpersonateLoggedOnUser API. ^[14]
S0439	Okrum	Okrum can impersonate a logged-on user's security context using a call to the ImpersonateLoggedOnUser API. ^[17]
S0192	Pupy	Pupy can obtain a list of SIDs and provide the option for selecting process tokens to impersonate. ^[18]
S0496	REvil	REvil can obtain the token from the user that launched the explorer.exe process to avoid affecting the desktop of the SYSTEM user. ^[19]
S0140	Shamoon	Shamoon can impersonate tokens using LogonUser, ImpersonateLoggedOnUser, and ImpersonateNamedPipeClient. ^[20]
S0692	SILENTRINITY	SILENTRINITY can find a process owned by a specific user and impersonate the associated token. ^[21]
S0623	Siloscape	Siloscape impersonates the main thread of CExecSvc.exe by calling NtImpersonateThread. ^[22]
S0603	Stuxnet	Stuxnet attempts to impersonate an anonymous token to enumerate bindings in the service control manager. ^[23]
S1011	Tarrask	Tarrask leverages token theft to obtain lsass.exe security permissions. ^[24]

Mitigations

ID	Mitigation	Description
M1026	Privileged Account Management	Limit permissions so that users and user groups cannot create tokens. This setting should be defined for the local system account only. GPO: Computer Configuration > [Policies] > Windows Settings > Security Settings > Local Policies > User Rights Assignment: Create a token object. ^[25] Also define who can create a process level token to only the local and network service through GPO: Computer Configuration > [Policies] > Windows Settings > Security Settings > Local Policies > User Rights Assignment: Replace a process level token. ^[26] Administrators should log in as a standard user but run their tools with administrator privileges using the built-in access token manipulation command runas. ^[27]
M1018	User Account Management	An adversary must already have administrator level access on the local system to make full use of this technique; be sure to restrict users and accounts to the least privileges they require.

Detection Strategy

ID	Name	Analytic ID	Analytic Description
DET0482	Behavior-chain detection for T1134.001 Access Token Manipulation: Token Impersonation/Theft on Windows	AN1324	Detection of token duplication and impersonation attempts by correlating suspicious command-line executions (e.g., runas) with API calls to DuplicateToken, DuplicateTokenEx, ImpersonateLoggedOnUser, or SetThreadToken. The chain includes the initial command execution or in-memory API invocation → token handle duplication or thread token assignment → a new or existing process assuming the impersonated user's context.

References

1. Microsoft. (2021, October 12). DuplicateToken function (securitybaseapi.h). Retrieved January 8, 2024.

15. Ungur, P. (n.d.). HAVOC. Retrieved August 4, 2025.

16. MSTIC. (2022, September 8). Microsoft investigates Iranian attacks against the Albanian

2. FireEye Labs. (2015, April 18). Operation RussianDoll: Adobe & Windows Zero-Day Exploits Likely Leveraged by Russia's APT28 in Highly-Targeted Attack. Retrieved April 24, 2017.

3. CheckPoint. (2020, May 7). Naikon APT: Cyber Espionage Reloaded. Retrieved May 26, 2020.

4. Vrabie, V., et al. (2021, March 10). FIN8 Returns with Improved BADHATCH Toolkit. Retrieved September 8, 2021.

5. Frankoff, S., Hartley, B. (2018, November 14). Big Game Hunting: The Evolution of INDRIK SPIDER From Dridex Wire Fraud to BitPaymer Targeted Ransomware. Retrieved January 6, 2021.

6. Strategic Cyber LLC. (2017, March 14). Cobalt Strike Manual. Retrieved May 24, 2017.

7. Strategic Cyber LLC. (2020, November 5). Cobalt Strike: Advanced Threat Tactics for Penetration Testers. Retrieved April 13, 2021.

8. Binary Defense. (n.d.). Emotet Evolves With new Wi-Fi Spreader. Retrieved September 8, 2023.

9. Office of Information Security, Health Sector Cybersecurity Coordination Center. (2023, November 16). Emotet Malware: The Enduring and Persistent Threat to the Health Sector. Retrieved June 19, 2024.

10. Martin Zucec. (2021, July 27). Deep Dive Into a FIN8 Attack - A Forensic Investigation. Retrieved September 1, 2021.

11. Symantec Threat Hunter Team. (2023, July 18). FIN8 Uses Revamped Sardonic Backdoor to Deliver Noberus Ransomware. Retrieved August 9, 2023.

12. FinFisher. (n.d.). Retrieved September 12, 2024.

13. Allievi, A., Flori, E. (2018, March 01). FinFisher exposed: A researcher's tale of defeating traps, tricks, and complex virtual machines. Retrieved July 9, 2018.

14. ESET Research. (2025, December 2). MuddyWater: Snakes by the riverbank. Retrieved February 17, 2026.

government. Retrieved August 6, 2024.

17. Hromcova, Z. (2019, July). OKRUM AND KETRICA: AN OVERVIEW OF RECENT KE3CHANG GROUP ACTIVITY. Retrieved May 6, 2020.

18. Nicolas Verdier. (n.d.). Retrieved January 29, 2018.

19. McAfee. (2019, October 2). McAfee ATR Analyzes Sodinokibi aka REvil Ransomware-as-a-Service – What The Code Tells Us. Retrieved August 4, 2020.

20. Mundo, A., Rocca, T., Saavedra-Morales, J., Beek, C.. (2018, December 14). Shamoon Returns to Wipe Systems in Middle East, Europe . Retrieved May 29, 2020.

21. Salvati, M. (2019, August 6). SILENTTRINITY Modules. Retrieved March 24, 2022.

22. Prizmant, D. (2021, June 7). Siloscape: First Known Malware Targeting Windows Containers to Compromise Cloud Environments. Retrieved June 9, 2021.

23. Nicolas Falliere, Liam O Murchu, Eric Chien 2011, February W32.Stuxnet Dossier (Version 1.4) Retrieved November 17, 2024.

24. Microsoft Threat Intelligence Team & Detection and Response Team . (2022, April 12). Tarrask malware uses scheduled tasks for defense evasion. Retrieved June 1, 2022.

25. Brower, N., Lich, B. (2017, April 19). Create a token object. Retrieved December 19, 2017.

26. Brower, N., Lich, B. (2017, April 19). Replace a process level token. Retrieved December 19, 2017.

27. Microsoft TechNet. (n.d.). Runas. Retrieved April 21, 2017.